

قرارات كتابية بالإجماع صادرة عن أعضاء مجلس إدارة
شركة لين تكنولوجيز السعودية لتقنية نظم المعلومات

بتاريخ
٢ مايو ٢٠٢٥

نحن، أعضاء مجلس إدارة شركة لين تكنولوجيز السعودية لتقنية نظم المعلومات كافة (يُشار إليها فيما يلي بـ "مجلس الإدارة")، وهي شركة ذات مسؤولية محدودة منظمة وقائمة بموجب قوانين المملكة العربية السعودية، تحمل رقم السجل التجاري ١٠١٠٦٢٢٠٩٠، عنوانها المسجل هو الدور الأول، مبنى رقم ٣٤٠٣، شارع الحاوي، ٧٤٦٥، حي حطين، ١٣٥١٦، الرياض، المملكة العربية السعودية (ويُشار إليها فيما يلي بـ "الشركة")، نقر بموافقتنا على اعتماد القرارات التالية:

١ - الموافقة واعتماد سياسة إدارة المخاطر (الإصدار ٤)

يقرّ مجلس الإدارة بموجب هذا القرار الموافقة واعتماد سياسة إدارة المخاطر (الإصدار 4) والمرفقة بهذا القرار في الملحق (أ). ويأتي هذا الإصدار منقحاً للسياسة الحالية، لا سيما الفصل 6.3 - المراقبة والمراجعة والتقارير، ليشمل نطاق مراجعات الأمان/اختبارات الاختراق التي تغطي التطبيقات الموجهة للإنترنت والأنظمة الداعمة لها.

٢ - الموافقة واعتماد ضوابط الأمن السيبراني في إدارة المشاريع (الإصدار ١)

يقرّ مجلس الإدارة بموجب هذا القرار الموافقة واعتماد ضوابط الأمن السيبراني في إدارة المشاريع، والمرفقة بهذا القرار في الملحق (ب)، والتي تُعزّز ممارسات الأمن السيبراني القائمة ضمن دورة حياة تطوير البرمجيات

بموجب هذا، تتم الموافقة على أي إجراءات سابقة تم اتخاذها من قبل مديري الشركة، أو من أي مفوض بالتوقيع، في ما يتعلق بما سبق ذكره، والتصديق عليها وإقرارها.

Signed by:

Hisham Al-Falih

E21BFCA04E2541D...

هشام الفالح

مدير ومفوض بالتوقيع

التاريخ: ٢ مايو ٢٠٢٥

UNANIMOUS WRITTEN RESOLUTIONS OF THE DIRECTORS
OF
Lean Technologies Saudi for Information Technology Company

DATED
May 02, 2025

We, being all the director(s) of Lean Technologies Saudi for Information Technology Company, (the “**Board**”), a limited liability company organised and existing under the laws of the Kingdom of Saudi Arabia, with registration number 1010622090 having its registered address at Floor No. 1, Building No. 3403, Al Hawi Street, 7465, Hiteen District, 13516, Riyadh, Saudi Arabia (the “**Company**”), hereby consent to the adoption of the following resolutions:

1. **Approval and Adoption of Risk Management Policy (Version 4):**

THAT, the Board hereby approves and adopts the Risk Management Policy (Version 4), attached hereto in Annexure A, which refines the existing policy, in specific, 'Chapter 6.3 - Monitoring, Review and Reporting' to include the scope of the security reviews/penetration testing covering internet-facing applications and supporting systems; and

2. **Approval and Adoption of Cybersecurity Controls in Project Management (Version 1):**

THAT, the Board hereby approves and adopts the Cybersecurity Controls in Project Management, attached hereto in Annexure B, which formalizes existing cybersecurity practices within the software development lifecycle.

THAT any prior actions taken by the Directors of the Company, or by any other Authorised Signatory, in connection with the foregoing be and are hereby approved, ratified and confirmed.

Hisham Al-Falih

Director & Authorised Signatory

Date: May 02, 2025

ANNEXURE A

الملحق (أ)



Lean Technologies

Risk Management Policy

Approving Authority	CEO
Owner	Compliance
Approval Date	May 2025
Next Scheduled Review	May 2026
Version	4
Status	Published
Document classification	Confidential - all Lean employees
Description	The purpose of this document is to outline the approach taken by Lean Technologies in relation to the identification, assessment and treatment of operational, reputational, enterprise and other risks to which the company is or may become exposed



Content

1. Document Purpose	3
2. Policy Statements	3
3. Responsibilities	4
4. Risk Management Definition	8
5. Risk Appetite	8
6. Risk Assessment Process	9
6.1 Identification and Assessment	9
6.2 Control and Mitigation	13
6.3 Monitoring ,Review and Reporting	13
7. Risk Management Methods	15
7.1 Risk & Control Self Assessments (RCSA)	15
8. Process and Policy Reviews	15
9. New Product / Process Assessment	15
10. Incidents Management and Reporting	16
11. Risk Systems	16
12. Periodic Review and Update	17
13. Effective Date	17
14. Manual Control and Distribution	17



1. Document Purpose

The purpose of the Policy is to assist Lean Technologies' (hereafter referred to as Lean) to adequately identify, measure, mitigate, control, monitor and report operational risk to key stakeholders for informed decision making. Overall, it is expected that this Policy will support Lean in minimizing operational losses in addition to improving the efficiency of its operations and control environment.

This Policy applies to all Lean employees and other parties acting on behalf of Lean (i.e., contractors, consultants, etc.) who are charged with carrying out Risk Management activities at Lean. Any deviation from the Policy requires the prior approval of the Risk and Compliance Committee.

2. Policy Statements

- Lean is committed to a strong risk management culture throughout the organization.
- The Risk and Compliance Committee shall approve and review the risk appetite statement for risks that articulates the level of operational and non-operational risks that Lean is willing to assume.
- Lean shall ensure developing, implementing and maintaining a risk management framework that is fully integrated into the Lean's overall risk management processes.
- Lean shall be committed to develop a clear, effective and robust governance structure with well defined, transparent and consistent lines of responsibility.
- Risk management is the responsibility of all employees across all levels of Lean.
- Business teams shall ensure the identification and assessment of the risks inherent in all material products, activities, processes and systems to make sure the inherent risks are well understood.
- Business teams have the primary responsibility to mitigate their risks; putting in place detailed procedures and controls enabling compliance with the risk framework in line with the risk appetite and tolerance defined by Lean.
- All new products, activities, or processes must be submitted to the Head of Infosec for review and assessment of risks affecting the product development and eventual launching.
- Lean shall ensure regular monitoring of risk profiles and material exposures to losses via appropriate reporting mechanisms at the Board, senior management, and business lines that support proactive management of risks.



3. Responsibilities

Board of Directors

Key responsibilities of the Board are the following:

- To direct Lean's Risk Management framework including policies, methodologies, systems, processes, procedures and people;
- To approve the Risk Management framework and undertake periodic reviews for any enhancements/modifications in line with the changing Risk profile of Lean;
- To approve any proposed changes in the Risk Management framework due to external market influences or strategic changes;
- To establish a clearly defined organizational structure for Risk with defined roles and responsibilities;
- To approve Lean's Risk appetite;
- To ensure that Risk strategies are in line to risk appetite and tolerance level of Lean; and
- To review Risk reports on a regular basis for assessing Lean's exposure to internal and external environments and frame strategies to overcome unacceptable Risks.

Overall, the Board in conjunction with the RCC and senior management shall ensure effective management and control of risks across Lean.

Chief Executive Officer (CEO)

Key responsibilities of the CEO are the following:

- To support the Head of Infosec in establishing, maintaining and implementing Lean's Risk Management Framework in line with the Board approved appetite for Risk;
- To evaluate the adequacy of resources committed as well as the effectiveness of policies, procedures, and techniques employed to Risk management activities; and
- To assess and monitor Lean's overall risk exposure.

Risk and Compliance Committee

Key responsibilities of the RCC committee are the following:

- To direct on behalf of the Board the implementation of a robust risk management framework at Lean;
- To define and propose an appropriate risk appetite for Lean risks to the Board;
- To approve the Risk Management Policy on at least an annual basis; and
- To provide guidance to the Board to manage the Risks across Lean.

General Counsel

Key responsibilities of the General Counsel are the following:



- To establish and recommend to Lean's CEO the Risk Management Framework (policies, methodologies, systems, processes, procedures and people) and ensure its proper implementation;
- To evaluate the adequacy of resources committed as well as the effectiveness of policies, procedures and techniques employed to Risk management activities;
- To assess and monitor the Lean's overall Risk exposure; and
- To review the periodical reporting of the Risk environment and key findings to the RCC.

Head of infosec

Key responsibilities of the Head of Infosec are the following:

- To develop and regularly enhance the Risk policies, framework and procedures and set guidelines to manage Risk of Lean;
- To work closely with all business & support teams in implementing the Risk Management policy and framework;
- To analyze risks for all existing as well as new products, processes and activities launched by Lean;
- To communicate Risk Management policies to staff and provide necessary training for the implementation of the Risk Management Framework;
- To identify and procure tools and technology requirements to enhance the risk management practices at Lean;
- To review the adequacy of controls to manage the overall risks associated with business activities;
- To recommend risk mitigation, transfer strategies and opportunities to the General Counsel;
- To implement recommendations/suggestions made through specific resolutions by the RCC committee.
- To monitor, review and report progress on risk assessments on an annual basis;
- To ensure tracking of risk data (losses and near misses) across Lean by creating a database of Losses/ Near Misses;
- To periodically monitor risk indicators across business and support teams and report action plans initiated for mitigating the risks identified on account of breaches;
- To gather information/data and analyze the risk profile of the business and support teams as well as at the level of Lean and communicate the risks to various levels of management;
- To design and implement risk reports for Risk. The Head of Infosec shall collect and consolidate relevant information from the business and support teams and summarize it in the reports for submission to RCC and other relevant stakeholders;
- To conduct risk assessment of outsourcing arrangement to ensure that the type and level of services to be provided and the contractual liabilities and obligations of the service provider should be clearly set out in a service agreement;
- To monitor and report on the Lean's Risks / exposures, incidents and losses against Lean's Risk appetite to the General Counsel in a timely manner;



- To act as a center of excellence on risk management by keeping up to date with new risk management techniques and all new risk regulatory requirements;
- To conduct periodic reviews of High-Risk business units to ensure effectiveness of Risk management; and
- Training of Risk Management on a timely basis to ensure understanding of the Risk Management framework parameters in an attempt to maintain standardization across all business units.

Compliance

Key responsibilities of Compliance are the following:

- To ensure that the Head of Infosec manages risk arising in view of non-compliance with any Internal requirement;
- To keep the Head of Infosec informed of any material compliance failures (e.g. failures that may attract a significant risk or legal or regulatory sanctions, material financial loss, or loss to reputation); and
- To facilitate exchange of relevant information between the Compliance team and the Head of Infosec as appropriate.

Human Resources

Key responsibilities of Human Resources are the following:

- To identify appropriate resources that have enough expertise, skills and experience across functions;
- To proclaim a "Principles of Code of Ethics" on a periodic basis through any form of internal communication;
- To ensure job rotation and segregation of functions for individuals with special skill sets who are placed in special (high risk) areas of business;
- To ensure that structured risk awareness processes are designed and regularly conducted across Lean covering all the teams/departments/functions;
- To closely coordinate with the Head of Infosec on trainings to be organized by the HR;
- To provide employees with adequate confidence to report any inappropriate incident with all fairness at any point of time;
- To ensure that the job descriptions/goals of staff recruited at all levels include a general responsibility of managing risks related to their respective jobs in addition to their primary functions/responsibilities; and
- To ensure succession plans are in place for key personnel.

Finance

Key responsibilities of Finance are the following:



- To coordinate with business units to open/maintain the relevant operational and non-operational loss/gain accounts on the internal system at Lean in order to facilitate the booking of related losses by the various teams and shall ensure that these losses are booked correctly in the appropriate accounts; and
- To prepare a consolidated report of losses approved and recorded during the Quarter (i.e. statement of all operational loss accounts) which shall be submitted to the Head of Infosec for reconciliation.

Information Technology

Key responsibilities of IT department are the following:

- To implement all automated controls requested by business and the Head of Infosec;
- To regularly update user access rights as per their assigned roles and responsibilities;
- To implement controls needed to avoid the risk of theft/leak of Lean confidential and critical information; and
- To ensure prompt resolution or contingent plan implementation in case of any system malfunction to avoid business disruption.

Business teams – Line Management

Key responsibilities of Business teams as the first line of defense are the following:

- To ensure that staff responsibilities and accountabilities are clearly communicated and understood across the business units;
- To work with the Head of Infosec to ensure that risk management policies and procedures are effectively communicated and implemented across the business units;
- To regularly review the business units' risk exposure to ensure that risk management requirements have been achieved;
- To implement processes for the reporting of operational loss events;
- To promote awareness of key risks and controls throughout the business units;
- To ensure that business units staff receive adequate training to enable them to effectively perform their roles and responsibilities.

Business teams - All Staff

Key responsibilities of Lean staff are the following:

- To ensure that risk in relation to roles, responsibilities and accountabilities are clearly understood;
- To familiarize themselves with the business team operational policies and procedures;
- To ensure that operational risk related issues are reported appropriately and on a timely basis;



- To report any operational and non-operational risk related issues identified during day-to-day activities to Business team heads;
- To seek support, advice and guidance as appropriate on risk related matters; and
- To undertake day-to-day activities with risk management in mind.

Internal Audit

- Key responsibilities of Internal Audit are the following:
- To examine and evaluate the adequacy and effectiveness of Lean's Risk management processes, internal control systems and the functioning of the internal control procedures laid down for management of Risk;
- To review and validate the methodologies used for loss capture, risk assessment and risk mitigation plans;
- To review the procedures in place to ensure that risks are managed in an integrated manner across all Lean;
- To confirm that risk management policies and procedures are followed in conformity with Lean's strategy, objectives, policy and guidelines and that all risk management activities are carried out with integrity;
- To share the audit findings with the Head of Infosec to act on the observations and rectify any deviations or non-compliances; and
- To conduct a follow up review and share any findings not resolved with RCC Committee

4. Risk Management Definition

Risk is the effect of uncertainty on objectives. In line with ISO 27000, risk is defined as the combination of the likelihood of an event occurring when a threat exploits a vulnerability and the impact of such an event on the organization.

5. Risk Appetite

The risk appetite is the amount of operational and non-operational risk exposure from an event that Lean is willing to accept based on its current and proposed business strategies and operations. It is Lean's objective to minimize all losses or reputational damage arising from operational and non-operational risk.

The Board recognizes that it is ultimately responsible for the risks to which Lean is subject. Consequently, the Board will review and approve the risk appetite levels proposed by RCC. The Board delegates the RCC to oversee the management of the risks within the Board's appetite and requires this committee to report to the Board periodically on risk exposure.



The risk appetite is determined, and shall not exceed the approved threshold percentage of Lean. The risk appetite statement shall be reviewed annually or earlier whenever there is any substantial change in business operations.

6. Risk Assessment Process

The risk management process defines key elements for managing operational and non-operational risk at Lean including the Identification and Assessment, Control and Mitigation and Monitoring and Reporting of risks as shown below:

6.1 Identification and Assessment

Risk Identification

The purpose of risk identification is to find, recognize, and record risks. It includes identifying the cause and source of a risk event, or circumstance that could have material impact on Lean. Furthermore, it covers identifying existing controls and the nature and design of these controls.

Lean should identify the inherent risk in all material products, activities, processes and systems and should ensure that before activities, processes and systems are introduced or undertaken, the risk inherent in them is subject to adequate assessment procedures. The Head of Infosec shall ensure that processes are in place to identify the risks associated with Lean's business activities and shall consider both internal factors such as Lean's structure, the nature of its activities, human resources, organizational changes and employee turnover, and external factors such as changes in the industry and technological advances for identification of risks that could hamper the achievement of operational objectives.

To appropriately manage risk, The Head of Infosec shall work closely with all the related business units wherein risk could occur and encourage them to adequately identify risks within their functions. operational and non-operational risks can be identified through RCSAs, Policy and Process Reviews, and New Product and Process Risk Assessments as indicated in the Risk Management Framework.

Risk Assessment

Risk Assessment provides an understanding of risks that could affect the achievement of business objectives, and the adequacy and effectiveness of controls in place. It provides the basis for decisions about the most appropriate approach to treat the risk. Risk assessment determines the consequences and the probabilities of the identified risks, considering the absence or presence of existing controls and their effectiveness. It assists in the decision making on which risks need treatment and the priority for the treatment. It includes comparing estimated levels of risk with tolerance levels and with other identified risks and setting the risk into the context of the business environment.



Risk Assessments at Lean shall consider the following:

- From a risk assessment and measurement point of view, operational and non-operational risk shall always be assessed at the level of events. Each event shall be analyzed in terms of its likelihood (i.e. the probability that an event may occur) and its impact (i.e. the consequences or effects if an event does occur);
- Whether Lean has policies, processes and procedures to control and/or mitigate material operational risks;
- Whether Lean periodically reviews its risk limitation and control strategies and adjust its operational and non-operational risk profile accordingly using appropriate strategies, considering its overall risk appetite and profile;
- Whether adequate information systems/analytical techniques/processes have been implemented to regularly monitor risk profiles and material exposures to losses. There should be regular reporting of pertinent information to Senior Management and the Board which supports the proactive management of risk;
- Whether internal practices/physical controls are in place as appropriate to control risks, in addition to segregation of duties;
- Whether Lean assesses the operational and non-operational risk inherent in all material products, activities, processes and systems; and
- Whether control activities are an integral part of the daily activities of Lean. An effective internal control system requires an appropriate control structure to be set up, with control activities defined at every business level.

Risk Treatment

The choice of the Risk treatment measure will essentially depend on the effectiveness of the measure in reducing the probability and impact of a given Risk and the cost and time involved in implementing the measure. Risk responses shall be any one of the following or a combination that will result in an effective measure. The following are guidelines for the selection of a suitable risk responses:

Avoid Risk (Terminate): In the event where the cost-benefit analysis proves that the benefit margin is less than the risk cost considering all types of risk that includes operational and non-operational risk, Lean shall opt for avoiding such risks. However, the decision to discontinue the activity or not even being introduced shall be approved by the Board / RCC considering the strategic objectives as well.

Mitigate Risk (Treat): All possible measures that will enable the reduction in the frequency or severity of loss occurrence shall be implemented as part of risk mitigation for the identified risks. The mitigation, primarily through internal controls, shall be prudently applied based on the prioritization of risks. Any measures introduced as part of risk mitigation shall be approved by the appropriate authority and adequately documented as part of process documentation and job descriptions.



Transfer Risk (Transfer): Where the internal control environment does not specifically provide the support for reducing or controlling operational and non-operational risks, Lean should decide on transferring these risks primarily through insurance or outsourcing. The risk appetite of Lean shall also be considered while implementing the risk transfer through insurance and outsourcing. Furthermore, the decision of risk transfer shall also consider the cost associated with such mitigation. Cost must not be higher than the expected loss on account of the activity in which the risk has been identified. Where it is possible to share the risks between Lean and the third party, the same should be explored and implemented. Any undesirable effects that could arise on account of risk transfer shall also be identified and accounted for at the time of decision by the appropriate authority.

Risk Acceptance (Tolerate): Lean should decide on accepting operational and non-operational risks where the cost-benefit analysis sufficiently provides justification that the expected loss could be less than the cost of risk mitigation. However, such acceptance is subject to setting up adequate thresholds for such risks and the escalation procedure in case of breach of thresholds.

Risk Treatment Plan

The risk assessor creates a risk treatment plan providing where possible the following information:

- The reasons for selected treatments, including where appropriate expected benefits
- Those responsible for approving the risk treatment plan
- Those responsible for implementing the risk treatment plan
- Proposed actions
- Resource requirements and contingencies
- Treatment performance measures and limitations
- Requirements for reporting and monitoring
- Timing and schedule for the risk treatment

The risk treatment plan is agreed with the risk owners.

- The risk treatment plan is implemented in accordance with Lean processes and the risk treatment plan itself. Treatment options are identified for each of the assessed risks and whether the risk is acceptable or if it must be controlled in line with criteria established in the risk management framework.
- Appropriate control objectives and controls are selected from those listed in Risk Management Framework. Residual risk is estimated once all controls have been identified. This is the level of risk remaining once the controls have been implemented.
- The final residual risk will then be shown in the risk assessment table for the threat-vulnerability combination. The risk assessor then summarizes all the selected control objectives and controls into the Statement of Applicability, which can then be drawn up together with justification for accepting/rejecting each ISO27001 control.
- A risk treatment plan is produced identifying the controls to mitigate risk, the risks being



addressed (or areas) with the actions to mitigate risk, priority, and responsibility. This risk treatment plan may be divided into sections or work patterns as appropriate.

- Much of the mitigation of risk is defining and documenting the practices currently in place to assist their auditability and accountability. Key risks or risk areas may be summarized in a short-form summary to aid planning and prioritization.
- The Risk Treatment Plan is reviewed and accepted by the Risk Owner. The risk treatment plan is updated as appropriate.
- The Risk Treatment Plan is drawn up after the initial risk assessment and shows how the controls are implemented. The result of implementing these controls is re-assessed as the residual risk.

The risk treatment report as output from the risk assessment tool is reviewed manually and from this the summary risk treatment plan report is derived. This shows the key areas that require additional actions over and above documentation.

- The Risk Treatment Plan is derived by inspection and review of the risk assessment and is reviewed and updated until all relevant risks have been suitably addressed at which time the Risk Treatment Plan may be archived. The risk assessment is reviewed upon significant change and at least annually.
- When new assets are acquired, the risk assessment is reviewed, and the new asset is risk assessed if the current risk assessment is insufficient. Such a risk assessment may result in either the existing risk treatment plan being updated, or a new risk treatment plan being defined as appropriate.

Validation of Risk Treatment Plans

As part of evaluating the effectiveness of risk treatment plans, The Head of Infosec should assess the effectiveness of the risk treatment plans. The validation should aim at following:

- Identifying breaches and operational and non-operational risk losses, which occur continuously over a period of time. Frequent occurrence of breaches could mean that the risk treatment plans have not been implemented as desired. There shall be a mechanism in place to identify multiple risk events occurring regularly. The Head of Infosec should carry out a trend analysis of breaches to analyze the ineffective risk mitigation plans;
- Carrying out causal analysis to identify the reason for the ineffectiveness of the risk treatment plans;
- Ensuring that business and support units take corrective action plans considering the ineffectiveness of the risk mitigation measures used in the past; and
- Escalating these instances to the senior management to resolve the issue if risk treatment plans are not properly implemented by the business and support units.



6.2 Control and Mitigation

Lean shall maintain a strong control environment that utilizes policies, processes and systems; appropriate internal controls; and appropriate risk mitigation and transfer strategies. Internal controls are designed to provide reasonable assurance that Lean will have efficient and effective operations; produce reliable financial reports; and comply with applicable laws and regulations. Lean shall ensure that its control environment is effective by implementing internal controls including but not limited to:

- Appropriate segregation of duties and dual layer of control;
- Clearly established authorities and/or processes for approval;
- Close monitoring of adherence to assigned risk thresholds or limits; and
- Appropriate staffing level and training to maintain expertise.

6.3 Monitoring ,Review and Reporting

Monitoring

Risk Monitoring involves a regular checking on the risk and control level. It is conducted on a periodic as well as ad-hoc basis. This step includes:

- Monitoring risk by business units and reporting to The Head of Infosec as per agreed frequency, comparing results to the target thresholds set during the risk identification process and identifying trends;
- Detecting changes to the risk profiles, its causes and sources; and
- Ensuring controls are effective and efficient in design and operation;
- Analyzing trends and changes in events, internal and external factors;
- Identifying emerging risks.

Review

Lean Tech must conduct regular cybersecurity reviews for all critical information assets to ensure security, compliance, and risk mitigation. Reviews must include risk assessment, security and penetration testing, compliance checks, and incident readiness.

- Frequency: At least annually or upon significant system changes.
- Responsibilities: The CISO and Risk Team oversee execution, with IT Security conducting assessments.
- Compliance: Internal Audit will verify adherence during periodic audits.

All Lean customer-facing and other externally accessible (internet-facing) services, applications, APIs and their supporting infrastructure shall undergo an independent third-party penetration test and at least once every twelve (12) months, or immediately after any material change or major release, whichever occurs first.



- Scope – Testing and review must cover the full attack surface of the live production environment, including web, mobile, cloud, network edge, and authentication / authorization components.
- Responsibilities – The Information Security team schedules and oversees the assessments; qualified external testers must be engaged for penetration testing.
- Reporting & Remediation – Results, risk ratings, and remediation deadlines are logged and reported to the C level within 30 days of test completion. All findings must be remediated following the vulnerability management SLAs
- Evidence Retention – Final reports and proof-of-fix documentation are retained for a minimum of three (3) years and made available to auditors on request.

Failure to comply may result in escalation to executive leadership.

Lean Tech must maintain an Audit Tracker and Improvement Log for recording cybersecurity reviews, ensuring transparency and accountability. Each review must include:

- Identified Issues: List of vulnerabilities, risks, or gaps.
- Recommended Actions: Remediation steps with assigned owners and timelines.
- Audit Tracker: All cybersecurity reviews must be recorded in an audit tracker, capturing review dates, findings, assigned actions, and status updates.

Lean Tech must conduct independent cybersecurity audits in accordance with generally accepted auditing standards, the SAMA Cybersecurity Framework, Lean's Audit Manual, and Lean's Audit Plan to ensure compliance, effectiveness of security controls, and identification of systemic risks.

Reporting

Risk Reporting includes notification of emerging risk, issues, and incidents within a business unit, to the Head of Infosec and to the respective committee. It shall be conducted on a periodic and formal basis (through reports and presentations) and on an ad hoc and informal basis. Risk Reporting ensures that risks are treated appropriately, and accountability is assigned and understood.

The objective of the reporting process is to ensure relevant information is provided to senior management and the Board to enable the proactive management of risks. The process ensures a consistent approach for providing information that enables appropriate decision making and action taking.

Lean teams shall ensure they adequately report any risks emanating from their operations to the Head of Infosec. The Head of Infosec shall in turn report to the CEO and RCC on the following items:

- Summary of major operational incidents for the period;
- Status of Risk Appetite Statements and any mitigating actions for breached metrics;
- Results of annual RCSAs conducted and risk profiles developed;



- Breached risk indicators trends for the period and analysis of reasons for breach;
- Changes to Risk Management Policies and Methodologies and approvals required for the same;
- Any exceptions/deviations from the Risk Management Framework;
- Follow-up and status of Action Plans belonging to the previous period;
- Results of cybersecurity reviews, including key findings, identified risks, recommended actions, and remediation progress;
- Reporting of cybersecurity review results to the respective business owner, ensuring accountability and oversight on identified risks and mitigation measures.
- Follow-up cybersecurity reviews shall be conducted to validate that:
 - All identified issues have been addressed;
 - Critical risks have been treated effectively;
 - All agreed actions are being managed on an ongoing basis.



7. Risk Management Methods

7.1 Risk & Control Self Assessments (RCSA)

The RCSA methodology enables Lean to identify inherent risk events within each activity and process, assess risk impact and likelihood, document existing controls and assess their effectiveness, establish residual risk ratings and mitigating action plans.

The responsibility for the RCSA process shall be shared among all employees of Lean. The RCSA process shall allow management directly responsible for a business function to:

- Participate in the assessment of internal control;
- Evaluate potential risks;
- Develop action plans to address identified weaknesses; and timely closure
- Assess the likelihood of achieving its business objectives.

RCSA includes, identifying and assessing inherent operational and non-operational risks which present a challenge in achieving business objectives. This includes the identification and testing of key controls in place to manage and mitigate key risks.

All managers must ensure risk assessments are conducted for their units/teams.

When using outsourcing services, managers shall ensure that the inherent risks in the services used by Lean are also subject to adequate assessment procedures.

All significant non-product changes including changes to processes, activities, systems and organizational operating set-ups shall undergo a Risk Assessment using the RCSA methodology.

RCSAs helps the Head of Infosec identify and track high risk functions and activities undertaken at Lean and establish action plans and to introduce mitigating controls for identified High Risk areas.

8. Process and Policy Reviews

The Head of Infosec as and when required, should assess the adequacy and effectiveness of risk managements processes and evaluate them to highlight improvements which shall consequently help enhance internal controls; and thereby minimize the possibility of errors/misappropriations with the consequent impact on financial/reputation risk and ensure that processes meet minimum standards of control set by Lean.

Policies, standard operating procedures, agreements, and any other documents that are considered to have inherent risks shall also be reviewed by the Head of Infosec on an ad-hoc basis.

9. New Product / Process Assessment

Lean ensures that before new products, activities and processes are introduced or undertaken, operational and non-operational risks inherent in them shall be subject to adequate assessment procedures.



Lean ensures the establishment of a product assessment and approval of residual risks in new or significantly changed products where formal risk approval of designated authorities shall be required. Participation and approval of key stakeholders such as Operations, IT, Legal, Compliance and Head of Infosec should be required for a comprehensive risk assessment.

10. Incidents Management and Reporting

Lean shall systematically capture all risk loss events and near misses and allocate them accordingly to the specified business lines.

Accordingly, all process owners shall promptly report on risk incidents. The Head of Infosec shall perform a root cause analysis for all major operational and non-operational Incidents.

The Head of Infosec shall record incidents in an Incident Management Database (IMD) to enable Lean to quantify its past operational and non-operational risk exposures. The IMD shall contain the information captured by the incident reporting process including all incidents involving an actual or potential financial impact (including near misses). The IMD shall be maintained by the Head of Infosec, based on the incident reports (near misses and actual losses) received from the relevant team. A report summarizing the contents of the database shall be completed on a periodic basis and reported to the General Counsel and consolidated into CEO and RCC reporting packs if considered appropriate.

11. Risk Systems

Lean shall maintain a Risk System that supports the Risk Management policy, procedures, and framework. The system shall be used across Lean. All operational and non-operational risk activities including, but not limited to; Incident Management, Risk and Control Self-Assessments, Key Risk Indicator Monitoring, Risk Action Plan Tracking, New Product and Process process Assessments shall be captured and stored in the system.

The system will be considered as a central repository for all Management reporting related to Risk Management.



12. Periodic Review and Update

The Policy shall be reviewed at least once per year, or more frequently if needed.

The RCC Committee shall approve amendments to the Framework based on recommendations submitted by the General Counsel. The proposed amendments shall be prepared in draft form by the General Counsel and shall be submitted with justifications for the amendments to be reviewed by the RCC Committee and CEO prior to submission and approval by the Board.

Any revision to this Policy shall specify the superseded version which shall be retained for future reference.

13. Effective Date

The Policy shall become effective immediately upon its approval by the RCC.

14. Manual Control and Distribution

The Head of Infosec is the custodian of this Policy and responsible for ensuring that it is maintained up to date. The Head of Infosec shall be committed to ensuring that this Policy is an accurate reflection of the applicable laws, regulations, and policies.

All relevant members shall be given access to the Policy and any updated versions in a non-editable format. This Policy shall remain confidential, and its content shall not be shared with anyone other than the designated members.

ANNEXURE B

الملحق (ب)



Lean Technologies

Cybersecurity controls in Project Management

Approving Authority	CEO
Prepared By	Head of InfoSec
Approval Date	May 2025
Next Scheduled Review	May 2026
Description	This document provides a consolidated process to add cybersecurity controls and practices into the project management methodology and software development lifecycle.
Version	1.0



Contents

TABLE OF CONTENTS

1.	Overview	3
1.1	Objective	3
1.2	Scope	3
1.3	Normative references	3
2.	Roles & Responsibilities (RACI)	3
3.	Process Overview	3
4.	Project Management Risk Register	4
5.	Governance & Metrics Governance & Metrics	5
6.	Appendix B – References	5



1. Overview

1.1 Objective

This methodology defines how Lean integrates cyber-security into every phase of its project management lifecycle to It supplements — but does not replace — the existing Change & Release Management and Secure SDLC processes by adding the missing governance elements identified by the external assessor.

1.2 Scope

Applies to all technology-enabled projects that introduce, modify, or retire information systems, products or services across Lean.

1.3 Normative references

- SAMA Cyber Security Framework v2 – Domain 3.3 Project and Change Management
- ISO/IEC 27001:2022 & 27005:2022
- Lean Change & Release Management process (internal)
- Lean Secure SDLC – Security Gates in “Road to Production” (internal)

2. Roles & Responsibilities (RACI)

Activity	Product Owner	Project/Product Manager (PM)	Cyber-Security lead	Risk Owner
Approve security objectives	A	R	C	C
Perform cyber security risk assessment	C	R	R	C
Maintain project management Risk Register	C	R	R	A
Independent review	I	C	C	C
Gate approvals	A	R	C	I

Legend – R: Responsible A: Accountable C: Consulted I: Informed

3. Process Overview

Lean follows a six-phase project lifecycle, mapped to Secure Software Development lifecycle.

Phase	Key Security Activities
0 Concept	Capture preliminary security impact & business value – during research and ideation phase. This is capture in Notion, under each Product Specification Template.
1 Initiation	• Document business case, business value and identified risks (including cyber security risks) • Appoint risk owners. • Perform Cyber-Security Risk Assessment



	• Populate Project Management Risk Register with date of assessment, phase, inherent risk, planned controls. • Security Go/No-Go checkpoint (in case the residual risk even after proposed security controls is above Lean risk appetite, a decision will require to be taken by the Product Owner)
2 Planning & Design	• Add the Security Requirements Specification into the product specifications • Threat-modelling (STRIDE). • Update Risk Register. • Technical Design Review + Security Review gate SG02
3 Build & Test	• Secure coding guidelines. • Snyk SAST/SCA + SonarQube gates in CI/CD • Manual & automated security testing. • Track findings in Jira; link to Risk Register.
4 Deploy & Transition	• Pre-production security review (penetration testing done by specialized security professional) • All high/critical risks mitigated • Release approval (Security, PM, Product Owner). Note: Additionally, once every 6 months, an independent external security review takes place (penetration testing).
5 Closure & Lessons Learned	• Post-implementation security review done on a regular basis (use of Nessus Infra VA scans and Web app scans) • Finalize Risk Register; hand over residual risks to operations. • Document security lessons learned for knowledge base.

4. Project Management Risk Register

The *Project Management – Risk Register* contains the following fields

Field	Description
ID	Unique numeric identifier for traceability.
Project / Feature	Name of the project, epic, product or feature to which the risk relates.
Risk Description	Statement of the risk scenario (Threat → Vulnerability → Impact).
Past incidents linked to the risk	Reference to any historical or industry incidents demonstrating relevance.
Risk Owner	Named individual accountable for managing the risk throughout the project.
Identification Date	Date the risk is first logged (auto-captured from Jira ticket creation); proves assessment occurs at project start.
Type	Strategic / Operational / Compliance / Financial, etc.
Severity (H / M / L)	Calculated during the cyber security risk assessment using the Likelihood × Impact matrix; stored as a single label for simplicity.
Status	Open / Mitigated / Accepted / Transferred – reflects current treatment state.
Implemented security controls	Existing controls that mitigate the risk
Security controls in treatment plan	Planned new or enhanced controls required to reduce risk to within appetite.



Control implementation status	Not Started / In Progress / Fully Implemented – tracked via pipeline automation where possible.
Residual Risk	Risk level after planned controls are (or are not) in place.
Risk status	Closed / Under Review – administrative flag for reporting.
Within Company Risk Appetite	Yes / No – determines escalation to CEO or RCC

5. Governance & Metrics Governance & Metrics

KPIs:

- KP01 # of vulnerabilities failing remediation Security Team SLAs
- KP11 # of performed Architecture Design Review
- KP12 # of infrastructure vulnerabilities identified and fixed by Infra VA
- KR06 # of Risk appetite breaches
- KR08 Number of New Risks Identified

6. Appendix B – References

- *Change & Release Management* process (internal)
- *Secure SDLC – Security Gates in the “Road to Production”* (internal)